

L2 - 9.2. Threat Modelling

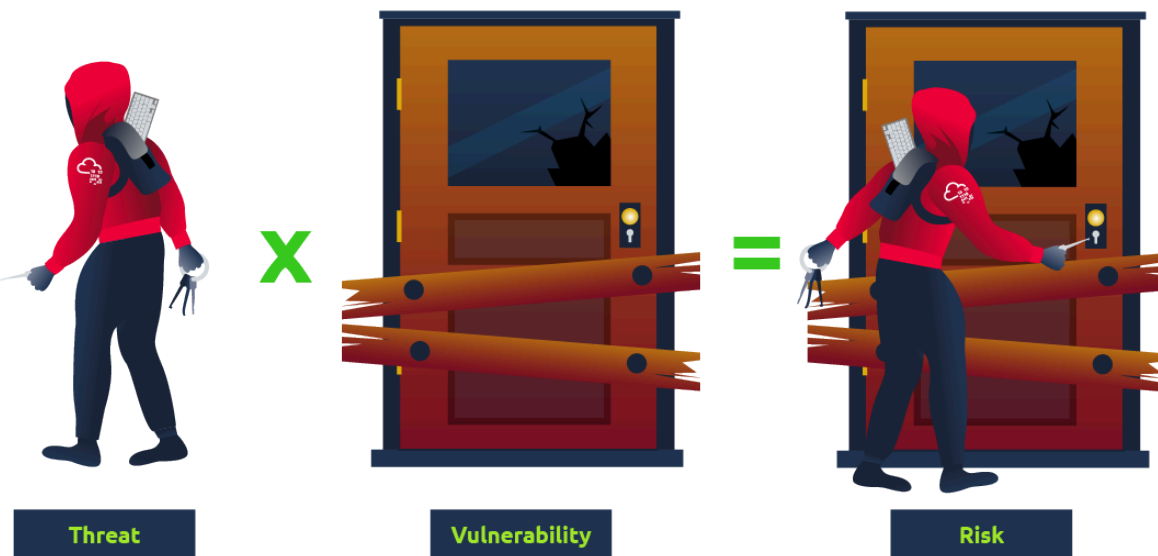
Task 1 - Introduction

Threat Modeling helps organizations identify, prioritize, and mitigate cyber risks to protect critical assets and strengthen security resilience.

Task 2 - Threat Modelling Overview

Threat Modeling is a structured cybersecurity process that identifies vulnerabilities, evaluates potential attack paths, prioritizes risks, and guides the implementation of effective security controls to strengthen organizational resilience. Threat modelling aims to reduce an organisation's overall risk exposure by identifying vulnerabilities and potential attack vectors, allowing for adequate security controls and strategies.

Type	Analogy
Threat	Occurrence of someone breaking inside your home and taking all your belongings.
Vulnerability	Weaknesses in your home security, such as broken locks or open windows.
Risk	Likelihood of being burglarised due to living in a neighbourhood with a high crime rate or a lack of an alarm system.



High-Level Process of Threat Modelling

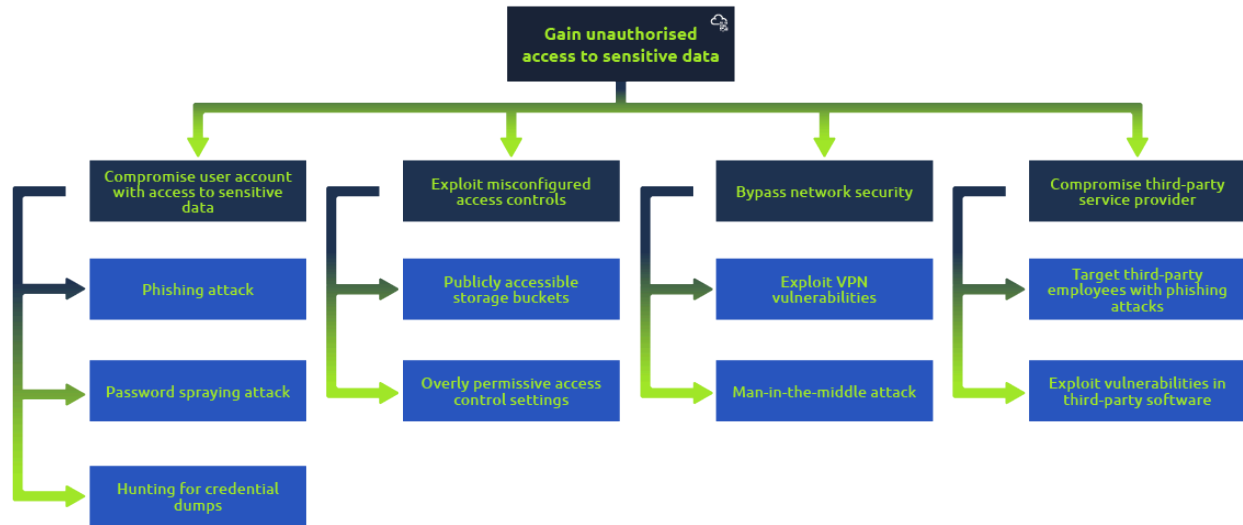
1. **Defining the scope:** Identify the systems, applications, and networks included in the threat modeling exercise.
2. **Asset Identification:** Map critical assets, architecture, dependencies, and the value of sensitive information.
3. **Identify Threats:** Determine potential threats such as cyberattacks, insider threats, physical attacks, and social engineering.
4. **Analyse Vulnerabilities and Prioritise Risks:** Assess vulnerabilities and prioritize risks based on their likelihood and potential impact.

5. **Develop and Implement Countermeasures:** Apply security controls to mitigate identified risks and strengthen defenses.
6. **Monitor and Evaluate:** Continuously monitor security controls and measure the effectiveness of risk mitigation efforts.

Collaboration with Different Teams

Team	Role and Purpose
Security Team	The overarching team of red and blue teams. This team typically lead the threat modelling process, providing expertise on threats, vulnerabilities, and risk mitigation strategies. They also ensure security measures are implemented, validated, and continuously monitored.
Development Team	The development team is responsible for building secure systems and applications. Their involvement ensures that security is always incorporated throughout the development lifecycle.
IT and Operations Team	IT and Operations teams manage the organisation's infrastructure, including networks, servers, and other critical systems. Their knowledge of network infrastructure, system configurations and application integrations is essential for effective threat modelling.
Governance, Risk and Compliance Team	The GRC team is responsible for organisation-wide compliance assessments based on industry regulations and internal policies. They collaborate with the security team to align threat modelling with the organisation's risk management objectives.
Business Stakeholders	The business stakeholders provide valuable input on the organisation's critical assets, business processes, and risk tolerance. Their involvement ensures that the efforts align with the organisation's strategic goals.
End Users	As direct users of a system or application, end users can provide unique insights and perspectives that other teams may not have, enabling the identification of vulnerabilities and risks specific to user interactions and behaviours.

Attack Trees: Attack Trees are a threat modeling technique that visually map an attacker's goals, strategies, and attack paths, helping organizations analyze vulnerabilities and understand how threats can progress toward a target.



Answer the questions below

What is a weakness or flaw in a system, application, or process that can be exploited by a threat?

vulnerability

Based on the provided high-level methodology, what is the process of developing diagrams to visualise the organisation's architecture and dependencies?

Asset Identification

What diagram describes and analyses potential threats against a system or application?

attack tree

Task 3 - Modelling with MITRE ATT&CK

Attack vector: The specific path, method, or entry point an attacker uses to breach a system.

Attack chain: The step-by-step sequence of actions a hacker executes—from initial access to ultimate objective—to complete a breach.

Carbanak: A sophisticated APT group and custom malware strain famed for stealing over \$1 billion directly from financial institutions via targeted spear-phishing and ATM manipulation.

Cobalt: A high-profile cybercrime syndicate known for using Cobalt Strike to orchestrate massive, automated targeted attacks against banks worldwide.

MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) is a comprehensive, globally accessible knowledge base of cyber adversary behaviour and tactics. Developed by the MITRE Corporation, it is a valuable resource for organisations to understand the different stages of cyber attacks and develop effective defences.

The ATT&CK framework is organised into a matrix that covers various tactics (high-level objectives) and techniques (methods used to achieve goals). The framework includes descriptions, examples, and mitigations for each technique, providing a detailed overview of threat actors' methods and tools.

As you can see in the provided link, the page contains five significant sections, namely:

1. **Technique Name and Details:** Information such as name, detailed explanation of the technique, types of data or logs that can help or detect, and platforms (Windows, MacOS, Linux) relevant to the technique.

Exploit Public-Facing Application

Adversaries may attempt to exploit a weakness in an Internet-facing host or system to initially access a network. The weakness in the system can be a software bug, a temporary glitch, or a misconfiguration.

Exploited applications are often websites/web servers, but can also include databases (like SQL), standard services (like SMB or SSH), network device administration and management protocols (like SNMP and Smart Install), and any other system with Internet accessible open sockets.^{[1][2][3][4][5]} Depending on the flaw being exploited this may also involve [Exploitation for Defense Evasion](#).

If an application is hosted on cloud-based infrastructure and/or is containerized, then exploiting it may lead to compromise of the underlying instance or container. This can allow an adversary a path to access the cloud or container APIs, exploit container host access via [Escape to Host](#), or take advantage of weak identity and access management policies.

Adversaries may also exploit edge network infrastructure and related appliances, specifically targeting devices that do not support robust host-based defenses.^{[6][7]}

For websites and databases, the OWASP top 10 and CWE top 25 highlight the most common web-based vulnerabilities.^{[8][9]}

ID: T1190

Sub-techniques: No sub-techniques

① **Tactic:** [Initial Access](#)

① **Platforms:** Containers, IaaS, Linux, Network, Windows, macOS

Contributors: Praetorian; Yossi Weizman, Azure Defender Research Team

Version: 2.4

Created: 18 April 2018

Last Modified: 14 April 2023

[Version Permalink](#)

2. **Procedure Examples:** Real-world examples of how threat actors have employed the technique in their adversarial operations.

Procedure Examples

ID	Name	Description
G0007	APT28	APT28 has used a variety of public exploits, including CVE-2020-0688 and CVE-2020-17144, to gain execution on vulnerable Microsoft Exchange; they have also conducted SQL injection attacks against external websites. ^{[1][11]}
G0016	APT29	APT29 has exploited CVE-2019-19781 for Citrix, CVE-2019-11510 for Pulse Secure VPNs, CVE-2018-13379 for FortiGate VPNs, and CVE-2019-9670 in Zimbra software to gain access. ^{[12][13]}
G0087	APT39	APT39 has used SQL injection for initial compromise. ^[14]
G0096	APT41	APT41 exploited CVE-2020-10189 against Zoho ManageEngine Desktop Central, and CVE-2019-19781 to compromise Citrix Application Delivery Controllers (ADC) and gateway devices. ^[15]
G0001	Axiom	Axiom has been observed using SQL injection to gain access to systems. ^{[16][17]}

3. **Mitigations:** Recommended security measures and best practices to protect against the technique.

Mitigations

ID	Mitigation	Description
M1048	Application Isolation and Sandboxing	Application isolation will limit what other processes and system features the exploited target can access.
M1050	Exploit Protection	Web Application Firewalls may be used to limit exposure of applications to prevent exploit traffic from reaching the application.
M1030	Network Segmentation	Segment externally facing servers and services from the rest of the network with a DMZ or on separate hosting infrastructure.
M1026	Privileged Account Management	Use least privilege for service accounts will limit what permissions the exploited process gets on the rest of the system.
M1051	Update Software	Update software regularly by employing patch management for externally exposed applications.
M1016	Vulnerability Scanning	Regularly scan externally facing systems for vulnerabilities and establish procedures to rapidly patch systems when critical vulnerabilities are discovered through scanning and through public disclosure. ^[8]

4. **Detections:** Strategies and indicators that can help identify the technique, as well as potential challenges in detecting the technique.

Detection

ID	Data Source	Data Component	Detects
DS0015	Application Log	Application Log Content	Detecting software exploitation may be difficult depending on the tools available. Software exploits may not always succeed or may cause the exploited process to become unstable or crash. Web Application Firewalls may detect improper inputs attempting exploitation.
DS0029	Network Traffic	Network Traffic Content	Use deep packet inspection to look for artifacts of common exploit traffic, such as SQL injection strings or known payloads.

5. **References:** External sources, reports, and articles that provide additional information, context, or examples related to the technique.

References

1. National Vulnerability Database. (2017, February 2). CVE-2016-6662 Detail. Retrieved April 3, 2018.
2. CIS. (2017, May 15). Multiple Vulnerabilities in Microsoft Windows SMB Server Could Allow for Remote Code Execution. Retrieved April 3, 2018.
3. US-CERT. (2018, April 20). [Russian State-Sponsored Cyber Actors Targeting Network Infrastructure Devices](#). Retrieved October 19, 2020.
4. Omar Santos. (2020, October 19). Attackers Continue to Target Legacy Devices. Retrieved October 20, 2020.
5. National Vulnerability Database. (2017, September 24). CVE-2014-7169 Detail. Retrieved April 3, 2018.
31. MSTIC. (2019, December 12). GALLIUM: Targeting global telecom. Retrieved January 13, 2021.
32. Counter Threat Unit Research Team. (2019, September 24). REvil/Sodinokibi Ransomware. Retrieved August 4, 2020.
33. MSTIC. (2021, March 2). HAFNIUM targeting Exchange Servers with 0-day exploits. Retrieved March 3, 2021.
34. Gruzweig, J. et al. (2021, March 2). Operation Exchange Marauder: Active Exploitation of Multiple Zero-Day Microsoft Exchange Vulnerabilities. Retrieved March 3, 2021.
35. Bromiley, M. et al. (2021, March 4). Detection and Response to Exploitation of Microsoft Exchange Zero-Day Vulnerabilities. Retrieved March 9, 2021.

Applying MITRE ATT&CK in Threat Modelling Process

MITRE ATT&CK can be integrated into our threat modelling process by mapping the identified threats and vulnerabilities to the tactics and techniques described in the ATT&CK Framework.

- **Identify Threats:** Identify potential threats that may impact the identified assets, such as cyber attacks, physical attacks, social engineering, and insider threats.
- **Map to MITRE ATT&CK:** Map the identified threats to the corresponding tactics and techniques in the MITRE ATT&CK Framework.

Utilising MITRE ATT&CK for Different Use Cases

MITRE ATT&CK can be used in various cases depending on your organisation's needs.

1. **Identifying potential attack paths based on your infrastructure:** Based on your assets, the framework can map possible attack paths an attacker might use to compromise your organisation.
2. **Developing threat scenarios:** MITRE ATT&CK has attributed all tactics and techniques to known threat groups.
3. **Prioritising vulnerability remediation:** The information provided for each MITRE ATT&CK technique can be used to assess the significant impact that may occur if your organisation experiences a similar attack.

Answer the questions below

What is the technique ID of "Exploit Public-Facing Application"? T1190

MITRE ATT&CK

Search

ATT&CKcon 7.0 is coming October 27-28, 2026. Learn more about ATT&CKcon 7.0 and submit your proposal.

TECHNIQUES

Exploit Public-Facing Application

External Remote Services

Hardware Additions

Phishing

Replication Through

Home > Techniques > Enterprise > Exploit Public-Facing Application

Exploit Public-Facing Application

Adversaries may attempt to exploit a weakness in an Internet-facing host or system to initially access a network. The weakness in the system can be a software bug, a temporary glitch, or a misconfiguration.

Exploited applications are often websites/web servers, but can also include databases (like SQL), standard services (like SMB or SSH), network device administration and management protocols (like SNMP and Smart Install), and any other system with Internet-accessible open sockets.^{[1][2][3][4][5]} On ESXi infrastructure, adversaries may exploit exposed OpenSLP services; they may alternatively exploit exposed VMware vCenter servers.^{[6][7]} Depending on the flaw being exploited, this may also involve [Exploitation for Stealth](#) or [Exploitation for Client Execution](#).

If an application is hosted on cloud-based infrastructure and/or is containerized, then exploiting it may lead to compromise of the underlying instance or container. This can allow an adversary a path to access the cloud or container APIs (e.g., via

ID: T1190

Sub-techniques: No sub-techniques

Tactic: [Initial Access](#)

Platforms: Containers, ESXi, IaaS, Linux, Network Devices, Windows, macOS

Contributors: Don Le, Stifel Financial; Praetorian; Yossi Weizman, Azure Defender Research Team

Version: 2.8

Created: 18 April 2018

Last Modified: 12 May 2026

Under what tactic does this technique belong? Initial Access

Task 4 - Mapping with ATT&CK Navigator

ATT&CK Navigator: Here is a brief overview of the steps and features we will utilise.

1. Creation of a new layer.
2. Searching and selecting techniques.
3. Viewing, sorting and filtering layers.
4. Annotating techniques with fills, scores and comments.

Creating a New Layer

To start with, let's create a new layer and choose enterprise.

MITRE ATT&CK® Navigator

The ATT&CK Navigator is a web-based tool for annotating and exploring ATT&CK matrices. It can be used to visualize defensive coverage, red/blue team planning, the frequency of detected techniques, and more.

[help](#)
[changelog](#)
[theme](#)

Create New Layer

Create a new empty layer

Enterprise

Mobile

ICS

More Options

Open Existing Layer

Load a layer from your computer or a URL

Create Layer from other layers

Choose layers to inherit properties from

Create Customized Navigator

Create a hyperlink to a customized ATT&CK Navigator

You may have observed that there are three options for creating a new layer. These layers pertain to the three MITRE ATT&CK matrices, namely:

- **Enterprise** - The Enterprise Matrix focuses on threats and techniques commonly used against enterprise networks.
- **Mobile** - The Mobile Matrix focuses on threats and techniques against mobile devices, such as smartphones and tablets.
- **ICS** - The ICS Matrix focuses on threats and techniques against industrial control systems, which control critical infrastructure, such as power plants, water treatment facilities, and transportation systems.

We have chosen the Enterprise Matrix to cover threat actors' typical techniques when targeting an organisation. After creating a new layer, you will have this view once the web page has loaded.

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
Active Scanning (001)	Acquire Infrastructure (007)	Drive-by Compromise (008)	Command and Scripting Interpreter (009)	Account Manipulation (005)	Abuse Elevation Control Mechanism (004)	Abuse Elevation Control Mechanism (004)	Adversary-in-the-Middle (003)	Account Discovery (004)	Exploitation of Remote Services (002)	Adversary-in-the-Middle (003)	Application Layer Protocol (004)	Automated Exfiltration (005)	Account Access Removal (006)
Gather Victim Host Information (001)	Compromise Accounts (007)	Exploit Public-Facing Application (008)	Container Administration Command (009)	BITS Jobs (005)	Access Token Manipulation (004)	Access Token Manipulation (004)	Brute Force (003)	Application Window Discovery (004)	Internal Spearphishing (002)	Archive Collected Data (003)	Communication Through Removable Media (004)	Data Transfer Size Limits (005)	Data Destruction (006)
Gather Victim Identity Information (002)	Compromise Infrastructure (007)	External Remote Services (008)	Deploy Container (009)	Boot or Logon Autostart Execution (005)	Boot or Logon Autostart Execution (004)	Boot or Logon Autostart Execution (004)	Credentials from Password Stores (003)	Browser Bookmark Discovery (004)	Lateral Tool Transfer (002)	Audio Capture (003)	Exfiltration Over Alternative Protocol (004)	Exfiltration Over C2 Channel (005)	Data Encrypted for Impact (006)
Gather Victim Network Information (003)	Develop Capabilities (007)	Hardware Additions (008)	Exploitation for Client Execution (009)	Boot or Logon Initialization Scripts (005)	Boot or Logon Initialization Scripts (004)	Boot or Logon Initialization Scripts (004)	Exploitation for Credential Access (003)	Cloud Infrastructure Discovery (004)	Remote Service Session Hijacking (002)	Automated Collection (003)	Data Encoding (004)	Exfiltration Over Other Network Medium (005)	Data Manipulation (006)
Gather Victim Org Information (004)	Establish Accounts (007)	Phishing (008)	Inter-Process Communication (009)	Browser Extensions (005)	Create or Modify System Process (004)	Create or Modify System Process (004)	Deobfuscate/Decode Files or Information (003)	Cloud Service Dashboard (004)	Remote Services (002)	Browser Session Hijacking (003)	Data Obfuscation (004)	Exfiltration Over C2 Channel (005)	Defacement (006)
Phishing for Information (005)	Obtain Capabilities (007)	Replication Through Removable Media (008)	Native API (009)	Compromise Client Software Binary (005)	Domain Policy Modification (004)	Domain Policy Modification (004)	Forge Web Credentials (003)	Cloud Service Discovery (004)	Replication Through Removable Media (002)	Clipboard Data (003)	Dynamic Resolution (004)	Exfiltration Over Other Network Medium (005)	Endpoint Denial of Service (006)
Search Closed Sources (006)	Stage Capabilities (007)	Supply Chain Compromise (008)	Scheduled Task/Job (009)	Create Account (005)	Escape to Host (004)	Escape to Host (004)	Input Capture (003)	Cloud Storage Object Discovery (004)	Encrypted Channel (002)	Data from Cloud Storage (003)	Encrypted Channel (004)	Exfiltration Over Physical Medium (005)	Firmware Corruption (006)
Search Open Technical Databases (007)	Trusted Relationship (007)	Serverless Execution (008)	Serverless Execution (009)	Create or Modify System Process (005)	Event Triggered Execution (004)	Event Triggered Execution (004)	Modify Authentication Process (003)	Container and Resource Discovery (004)	Software Deployment Tools (002)	Data from Configuration Repository (003)	Fallback Channels (004)	Exfiltration Over Physical Medium (005)	Inhibit System Recovery (006)
Search Open Websites/Domains (008)	Valid Accounts (007)	Software Deployment Tools (008)	System Services (009)	External Remote Services (005)	Hijack Execution Flow (004)	Hijack Execution Flow (004)	Multi-Factor Authentication Interception (003)	Debugger Evasion (004)	Taint Shared Content (002)	Data from Information Repositories (003)	Ingress Tool Transfer (004)	Exfiltration Over Web Service (005)	Network Denial of Service (006)
Search Victim-Owned Websites (009)	Windows Management Instrumentation (007)	User Execution (008)	Windows Management Instrumentation (009)	Hijack Execution Flow (005)	Process Injection (004)	Process Injection (004)	Network (003)	File and Directory Discovery (004)	Use Alternate Authentication Material (002)	Data from Local System (003)	Non-Application Layer Protocol (004)	Scheduled Transfer (005)	Resource Hijacking (006)
				Implant Internal Image (005)	Scheduled Task/Job (004)	Scheduled Task/Job (004)	OS Credential Dumping (003)	File and Directory Permissions Modification (004)	Data from Network Shared Drive (003)	Data from Removable Media (003)	Non-Standard Port (004)	Transfer Data to Cloud Account (005)	Service Stop (006)
				Modify Authentication Process (005)	Valid Accounts (004)	Valid Accounts (004)	Steal Application Access Token (003)	Group Policy Discovery (004)	Proxy (002)	Email Collection (003)	Remote Access Software (004)	System Shutdown/Reboot (005)	
				Office Application Startup (005)			Masquerading (003)	Network Service Discovery (004)	Input Capture (002)	Traffic Signaling (003)	Web Service (004)		
				Pre-OS Boot (005)			Steal or Forge Authentication Certificates (003)	Peripheral Device Discovery (004)	Screen Capture (002)	Video Capture (003)			
				Scheduled Task/Job (005)			Steal or Forge Kerberos Tickets (003)	Permission Groups Discovery (004)					
				Server Software (005)				Process Discovery (004)					

Searching and Selecting Techniques

The first important feature we want to utilise in this application is the search functionality under the **Selection Controls** panel. This feature allows us to search and multi-select techniques you want to highlight or mark.

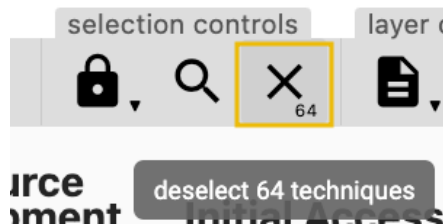
You may press the magnifier button to access the right sidebar, search using any keywords, or choose any selection under **Techniques, Threat Groups, Software, Mitigations, Campaigns, or Data Sources**.

The screenshot shows the MITRE ATT&CK framework interface. The main table lists techniques across various categories. On the right, the 'Threat Groups' section is active, showing a search for 'APT41'. The search results indicate that APT41 is associated with 594 techniques. The interface includes a search bar, search settings, and a list of threat groups.

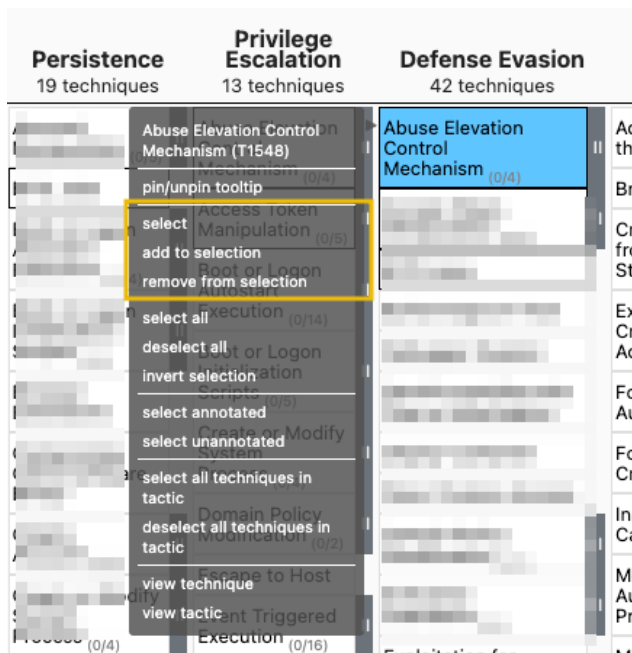
For a quick example, search for **APT41** and hover its entry on the **Threat Groups** section. You may observe that it will highlight all techniques attributed to this threat group. Once you click the select button, the highlighted techniques will be selected as a group and can be annotated with a score or a background fill, which will be discussed in the following instructions.

The screenshot shows the MITRE ATT&CK framework interface with the search results for 'APT41'. The search results indicate that APT41 is associated with 594 techniques. The interface includes a search bar, search settings, and a list of threat groups. The 'APT41' entry is highlighted, and the 'select' button is visible.

After selecting the threat group, you may also observe that the deselect button now has a numerical value. This indicates the current number of chosen techniques. You may press this button to remove all your current technique selections.



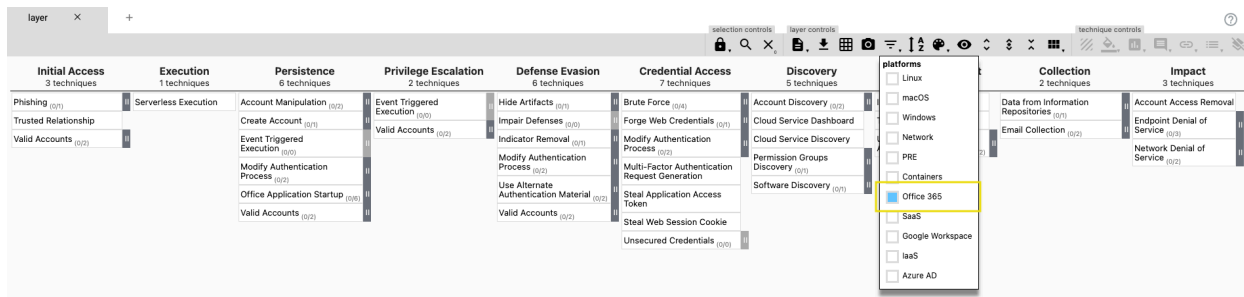
Lastly, you may right-click any technique if you prefer to do an action on a single technique (e.g. select, add to selection, remove from selection).



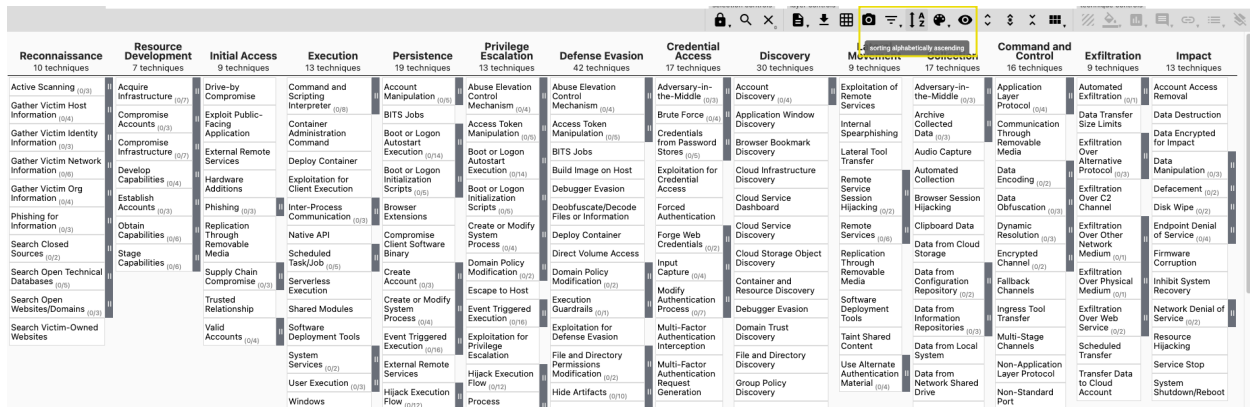
Viewing, Sorting and Filtering Layers

We will tackle the next set of features under the **Layer Controls** panel. However, we will only focus on the following:

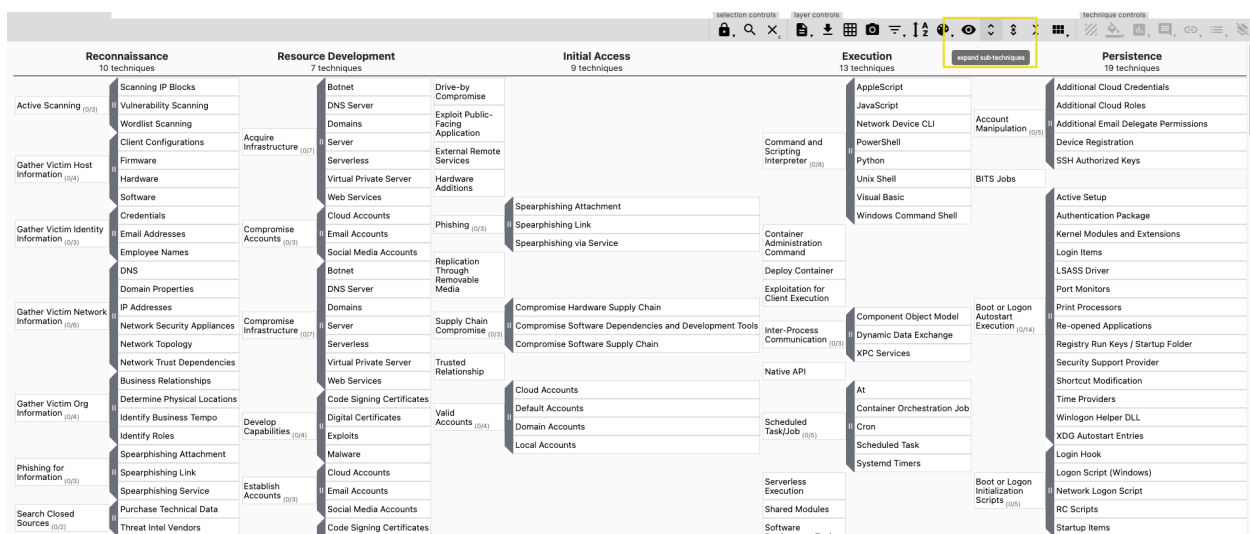
- Exporting features (download as JSON, Excel, SVG) - This allows you to dump the selected techniques, including all annotations. The data exported can be ingested again in the ATT&CK Navigator for future use.
- Filters - Allows you to filter techniques based on relevant platforms, such as operating systems or applications. For a quick example, the image below shows all techniques that are attributed to Office365.



- **Sorting** - This allows you to sort the techniques by their alphabetical arrangement or numerical scores. The image below shows that all techniques are arranged alphabetically.



- **Expand sub-techniques** - View all underlying sub-techniques under each technique, expanding the view for all techniques. You will have a similar view with the image below once you have expanded the sub-techniques.

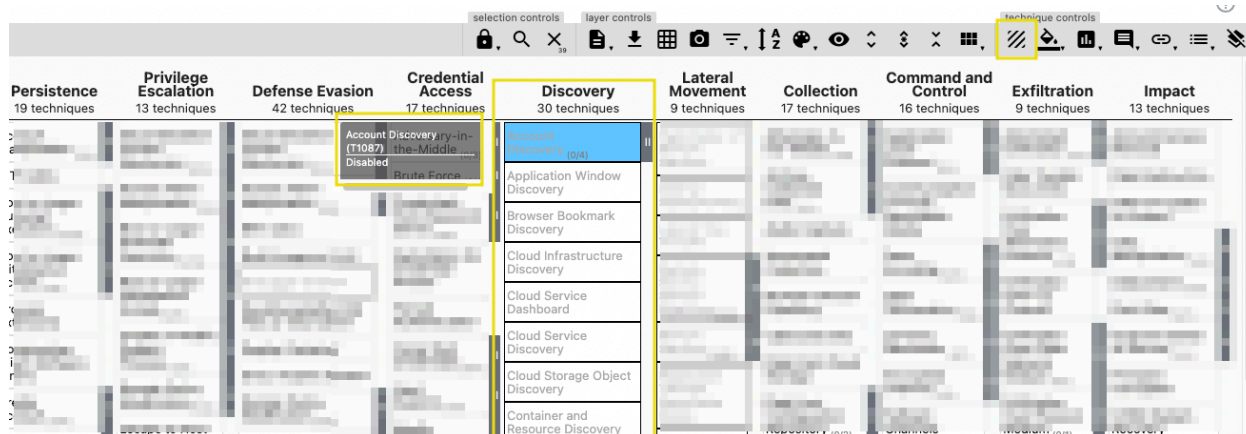


Annotating Techniques

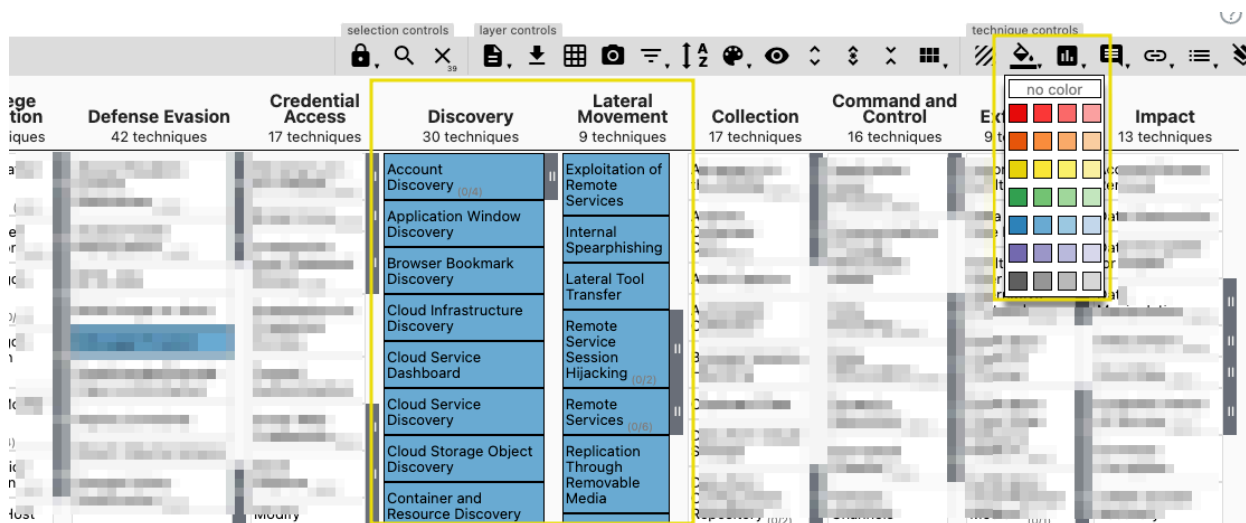
Now, the last set of features is under the **Technique Controls** panel. These buttons allow you to annotate details on selected techniques. For a quick run-through, here are the features under the panel mentioned (from left to right):



- **Toggle state** - This feature allows you to disable the selected techniques, making their view greyed-out.

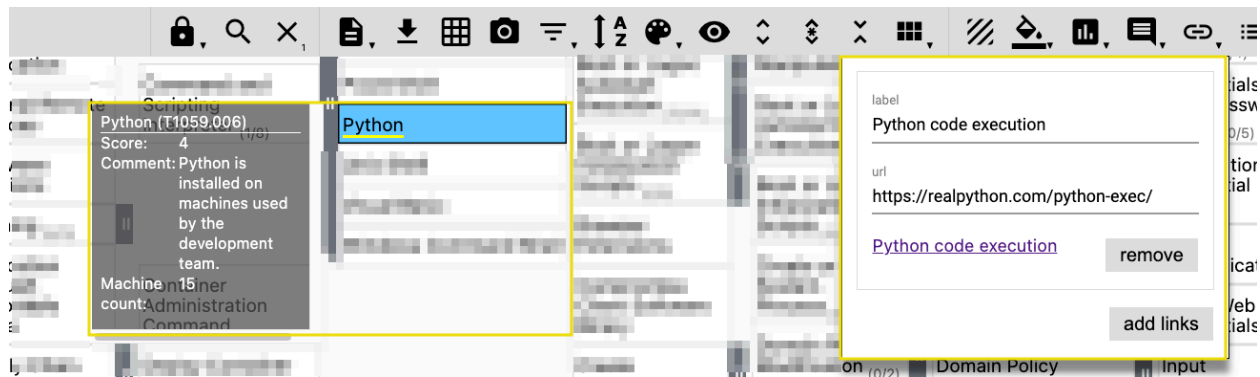


- Background color - This allows you to change the background color of the selected technique, for highlighting and grouping purposes.



- Scoring - Allows you to rate each technique or set of techniques based on criteria depending on your needs, such as the impact of a technique.
- Comment - Allows you to add notes and observations to a technique.
- Link - Allows you to add external links, such as additional references related to the technique.
- Metadata - Allows you to add custom tags and labels to a particular technique.
- Clear annotations on selected - Remove all annotations on selected techniques.

The image below is an example of using Scoring, Comment, Link and Metadata features.



Utilising ATT&CK Navigator

You are tasked to utilise the MITRE ATT&CK framework for your threat modelling exercise. The organisation you're currently working with is in the financial services industry. Given that, some known threat groups targeting this industry are:

- APT28 (Fancy Bear)
- APT29 (Cozy Bear)
- Carbanak
- FIN7 (Carbanak/Fancy Bear)
- Lazarus Group

In addition, your organisation uses the following technologies:

- Google Cloud Platform (GCP) for cloud infrastructure
- Online banking platform developed by internal developers
- A Customer Relationship Management (CRM) platform

Lastly, the critical assets that you handle based on your business stakeholders are the following:

- Customer financial data
- Transaction records
- Personally identifiable information (PII)

Given this scenario, you can use the MITRE ATT&CK framework and ATT&CK Navigator to map and understand the significant techniques attributed to the provided threat groups and those affecting GCP and web applications.

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement
10 techniques	7 techniques	9 techniques	13 techniques	19 techniques	13 techniques	42 techniques	17 techniques	30 techniques	9 techniques
Active Scanning (0/3)	Acquire Infrastructure (0/7)	Drive-by Compromise (0/7)	Command and Scripting Interpreter (0/8)	Account Manipulation (0/8)	Abuse Elevation Control Mechanism (0/4)	Abuse Elevation Control Mechanism (0/4)	Adversary-in-the-Middle (0/3)	Account Discovery (0/4)	Exploitation of Remote Services (0/4)
Gather Victim Host Information (0/4)	Compromise Accounts (0/3)	Exploit Public-Facing Application (0/3)	Container Administration Command (0/4)	BITS Jobs (0/4)	Access Token Manipulation (0/5)	Access Token Manipulation (0/5)	Brute Force (0/4)	Application Window Discovery (0/4)	Internal Spearfishing (0/4)
Gather Victim Identity Information (0/3)	Compromise Infrastructure (0/7)	External Remote Services (0/7)	Deploy Container (0/4)	Boot or Logon Autostart Execution (0/4)	Boot or Logon Autostart Execution (0/4)	Boot or Logon Autostart Execution (0/4)	Credentials from Password Stores (0/5)	Browser Bookmark Discovery (0/5)	Lateral Tool Transfer (0/4)
Gather Victim Network Information (0/4)	Develop Capabilities (0/4)	Hardware Additions (0/4)	Exploitation for Client Execution (0/4)	Boot or Logon Initialization Scripts (0/5)	Boot or Logon Initialization Scripts (0/5)	Boot or Logon Initialization Scripts (0/5)	Exploitation for Credential Access (0/5)	Cloud Infrastructure Discovery (0/5)	Remote Service Session Hijacking (0/2)
Gather Victim Org Information (0/4)	Establish Accounts (0/3)	Phishing (0/3)	Inter-Process Communication (0/3)	Browser Extensions (0/4)	Create or Modify System Process (0/4)	Create or Modify System Process (0/4)	Forced Authentication (0/4)	Cloud Service Dashboard (0/5)	Remote Services (0/6)
Phishing for Information (0/3)	Obtain Capabilities (0/6)	Replication Through Removable Media (0/6)	Native API (0/4)	Compromise Client Software Binary (0/4)	Domain Policy Modification (0/2)	Domain Policy Modification (0/2)	Forge Web Credentials (0/5)	Cloud Storage Object Discovery (0/4)	Replication Through Removable Media (0/4)
Search Closed Sources (0/2)	Stage Capabilities (0/6)	Supply Chain Compromise (0/3)	Scheduled Task/Job (0/5)	Serverless Execution (0/4)	Escape to Host (0/4)	Escape to Host (0/4)	Input Capture (0/4)	Container and Resource Discovery (0/4)	Software Deployment Tools (0/4)
Search Open Technical Databases (0/2)	Trusted Relationship (0/4)	Valid Accounts (0/4)	Shared Modules (0/4)	Create or Modify System Process (0/4)	Event Triggered Execution (0/6)	Event Triggered Execution (0/6)	Modify Authentication Process (0/7)	Debugger Evasion (0/4)	Taint Shared Content (0/4)
Search Open Websites/Domains (0/3)	User Execution (0/3)		System Services (0/2)	External Remote Services (0/3)	Hijack Execution Flow (0/12)	Hijack Execution Flow (0/12)	Multi-Factor Authentication Interception (0/7)	File and Directory Discovery (0/4)	Use Alternate Authentication Material (0/4)
Search Victim-Owned Websites (0/3)	Windows Management Instrumentation (0/3)		Windows Management Instrumentation (0/3)	Hijack Execution Flow (0/12)	Process Injection (0/12)	Process Injection (0/12)	Multi-Factor Authentication Request Generation (0/4)	Network Service Discovery (0/4)	
				Scheduled Task/Job (0/5)	Scheduled Task/Job (0/5)	Scheduled Task/Job (0/5)	Network Sniffing (0/4)	Network Share Discovery (0/4)	
					Valid Accounts (0/4)	Valid Accounts (0/4)	OS Credential Dumping (0/4)	Network Sniffing (0/4)	
					Office Application (0/6)	Office Application (0/6)	Steal Application Access Token (0/4)	Peripheral Device Discovery (0/4)	
					Pre-OS Boot (0/5)	Pre-OS Boot (0/5)	Steal or Forge Authentication Certificates (0/4)	Permission Groups Discovery (0/3)	
					Scheduled Task/Job (0/5)	Scheduled Task/Job (0/5)	Steal or Forge Kerberos (0/4)		

Techniques used by APT28

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement
10 techniques	7 techniques	9 techniques	13 techniques	19 techniques	13 techniques	42 techniques	17 techniques	30 techniques	9 techniques
Active Scanning (0/3)	Acquire Infrastructure (0/7)	Drive-by Compromise (0/7)	Command and Scripting Interpreter (0/8)	Account Manipulation (0/8)	Abuse Elevation Control Mechanism (0/4)	Abuse Elevation Control Mechanism (0/4)	Adversary-in-the-Middle (0/3)	Account Discovery (0/4)	Exploitation of Remote Services (0/4)
Gather Victim Host Information (0/4)	Compromise Accounts (0/3)	Exploit Public-Facing Application (0/3)	Container Administration Command (0/4)	BITS Jobs (0/4)	Access Token Manipulation (0/5)	Access Token Manipulation (0/5)	Brute Force (0/4)	Application Window Discovery (0/4)	Internal Spearfishing (0/4)
Gather Victim Identity Information (0/3)	Compromise Infrastructure (0/7)	External Remote Services (0/7)	Deploy Container (0/4)	Boot or Logon Autostart Execution (0/4)	Boot or Logon Autostart Execution (0/4)	Boot or Logon Autostart Execution (0/4)	Credentials from Password Stores (0/5)	Browser Bookmark Discovery (0/5)	Lateral Tool Transfer (0/4)
Gather Victim Network Information (0/4)	Develop Capabilities (0/4)	Hardware Additions (0/4)	Exploitation for Client Execution (0/4)	Boot or Logon Initialization Scripts (0/5)	Boot or Logon Initialization Scripts (0/5)	Boot or Logon Initialization Scripts (0/5)	Exploitation for Credential Access (0/5)	Cloud Infrastructure Discovery (0/5)	Remote Service Session Hijacking (0/2)
Gather Victim Org Information (0/4)	Establish Accounts (0/3)	Phishing (0/3)	Inter-Process Communication (0/3)	Browser Extensions (0/4)	Create or Modify System Process (0/4)	Create or Modify System Process (0/4)	Forced Authentication (0/4)	Cloud Service Dashboard (0/5)	Remote Services (0/6)
Phishing for Information (0/3)	Obtain Capabilities (0/6)	Replication Through Removable Media (0/6)	Native API (0/4)	Compromise Client Software Binary (0/4)	Domain Policy Modification (0/2)	Domain Policy Modification (0/2)	Forge Web Credentials (0/5)	Cloud Storage Object Discovery (0/4)	Replication Through Removable Media (0/4)
Search Closed Sources (0/2)	Stage Capabilities (0/6)	Supply Chain Compromise (0/3)	Scheduled Task/Job (0/5)	Serverless Execution (0/4)	Escape to Host (0/4)	Escape to Host (0/4)	Input Capture (0/4)	Container and Resource Discovery (0/4)	Software Deployment Tools (0/4)
Search Open Technical Databases (0/2)	Trusted Relationship (0/4)	Valid Accounts (0/4)	Shared Modules (0/4)	Create or Modify System Process (0/4)	Event Triggered Execution (0/6)	Event Triggered Execution (0/6)	Modify Authentication Process (0/7)	Debugger Evasion (0/4)	Taint Shared Content (0/4)
Search Open Websites/Domains (0/3)	User Execution (0/3)		System Services (0/2)	External Remote Services (0/3)	Hijack Execution Flow (0/12)	Hijack Execution Flow (0/12)	Multi-Factor Authentication Interception (0/7)	File and Directory Discovery (0/4)	Use Alternate Authentication Material (0/4)
Search Victim-Owned Websites (0/3)	Windows Management Instrumentation (0/3)		Windows Management Instrumentation (0/3)	Hijack Execution Flow (0/12)	Process Injection (0/12)	Process Injection (0/12)	Multi-Factor Authentication Request Generation (0/4)	Network Service Discovery (0/4)	
				Scheduled Task/Job (0/5)	Scheduled Task/Job (0/5)	Scheduled Task/Job (0/5)	Network Sniffing (0/4)	Network Share Discovery (0/4)	
					Valid Accounts (0/4)	Valid Accounts (0/4)	OS Credential Dumping (0/4)	Network Sniffing (0/4)	
					Office Application (0/6)	Office Application (0/6)	Steal Application Access Token (0/4)	Peripheral Device Discovery (0/4)	
					Pre-OS Boot (0/5)	Pre-OS Boot (0/5)	Steal or Forge Authentication Certificates (0/4)	Permission Groups Discovery (0/3)	
					Scheduled Task/Job (0/5)	Scheduled Task/Job (0/5)	Steal or Forge Kerberos (0/4)		

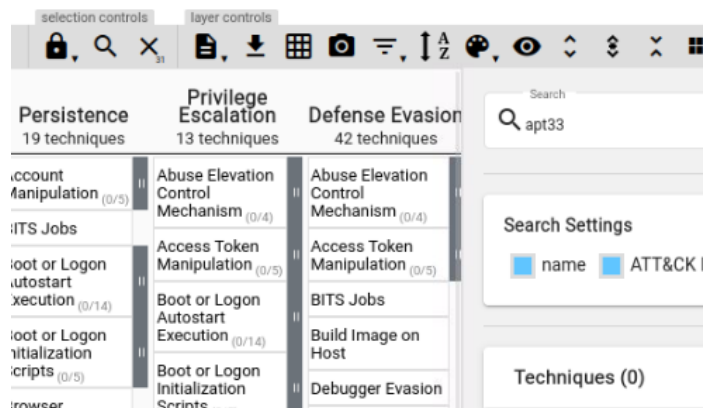
Techniques related to Google Cloud

Once these techniques are identified, you should prioritise the potential vulnerabilities that may affect the systems that handle your critical assets (financial data, transaction records, and PII). Some of the techniques that you may consider prioritising are the following:

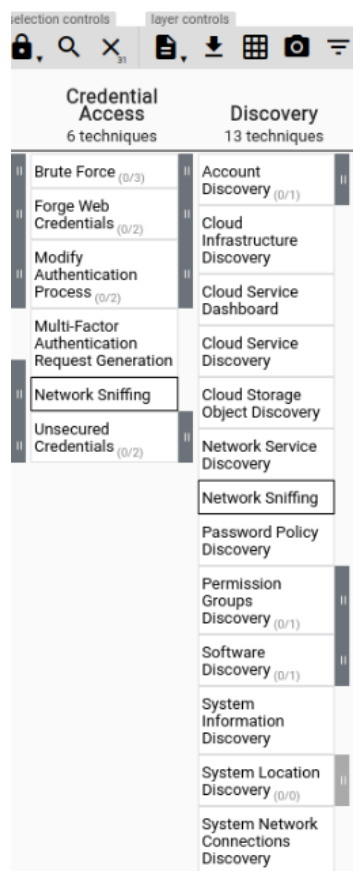
- **Exploit Public-Facing Application (T1190)** - Securing the public-facing application is crucial to prevent unauthorised access attempts.
- **Exploitation for Privilege Escalation (T1068)** - The prevention of escalating attackers' privileges reduces the chances of obtaining critical data only accessible to administrators.
- **Data from Cloud Storage (T1530)** - Since the cloud instance contains critical data, safeguarding the confidentiality and integrity of the data stored is crucial.
- **Network Denial of Service (T1498)** - The technique may not directly target the critical data within the cloud instance. Still, it can lead to service disruptions and potential impacts on the availability and accessibility of the data.

Answer the questions below

How many MITRE ATT&CK techniques are attributed to APT33? 31



Upon applying the IaaS platform filter, how many techniques are under the Discovery tactic? 13



Task 5 - DREAD Framework

The DREAD framework is a risk assessment model developed by Microsoft to evaluate and prioritise security threats and vulnerabilities. It is an acronym that stands for:

DREAD	Definition
-------	------------

Damage	The potential harm that could result from the successful exploitation of a vulnerability. This includes data loss, system downtime, or reputational damage.
Reproducibility	The ease with which an attacker can successfully recreate the exploitation of a vulnerability. A higher reproducibility score suggests that the vulnerability is straightforward to abuse, posing a greater risk.
Exploitability	The difficulty level involved in exploiting the vulnerability considering factors such as technical skills required, availability of tools or exploits, and the amount of time it would take to exploit the vulnerability successfully.
Affected Users	The number or portion of users impacted once the vulnerability has been exploited.
Discoverability	The ease with which an attacker can find and identify the vulnerability considering whether it is publicly known or how difficult it is to discover based on the exposure of the assets (publicly reachable or in a regulated environment).

The categories are commonly phrased with the following questions to ingest the definitions provided above quickly:

- **Damage** - How bad would an attack be?
- **Reproducibility** - How easy is it to reproduce the attack?
- **Exploitability** - How much work is it to launch the attack?
- **Affected Users** - How many people will be impacted?
- **Discoverability** - How easy is it to discover the vulnerability?

DREAD Framework Guidelines

1. Establish a standardised set of guidelines and definitions for each DREAD category that provides a consistent understanding of how to rate vulnerabilities.
2. Encourage collaboration and discussion among multiple teams. Constructive feedback from different members aids in justifying the assigned scores, which can lead to a more accurate assessment.
3. Use the DREAD framework with other risk-assessment methodologies and regularly review and update the chosen methods and techniques to ensure they remain relevant and aligned with the organisation's needs.

Qualitative Analysis Using DREAD Framework

The DREAD Framework is typically used for Qualitative Risk Analysis, rating each category from one to ten based on a subjective assessment and interpretation of the questions above.

DREAD Score	2.5	5	7.5	10
Damage	Minimal infrastructure information disclosure	Minimal information disclosure related to client data	Limited PII leak	Complete data leak
Reproducibility	Multiple attack vectors requiring technical expertise	Minor customisation for public exploits needed	Little prerequisite technical skills needed to run the exploit	Users with public exploits can successfully reproduce the exploit
Exploitability	Almost no public exploits are available and need customisation of scripts	Complicated exploit scripts available in the wild	Minimal technical skills are required to execute public exploits	Reliable Metasploit module exists

Affected Users	Almost none to a small subset	Around 10% of users	More than half of the user base	All users
Discoverability	The significant effort needed to discover the vulnerability chains for the exploit to work	Requires a manual way of verifying the vulnerability	Public scanning scripts not embedded in scanning tools exist	Almost all known scanning tools can find the vulnerability

Given this guideline, we can assess some known vulnerabilities in the application. Below is an example of scoring provided for each vulnerability.

1. Unauthenticated Remote Code Execution (Score: 8)

- Damage (D): **10**
- Reproducibility (R): **7.5**
- Exploitability (E): **10**
- Affected Users (A): **10**
- Discoverability (D): **2.5**

2. Insecure Direct Object References (IDOR) in User Profiles (Score: 6.5)

- Damage (D): **2.5**
- Reproducibility (R): **7.5**
- Exploitability (E): **7.5**
- Affected Users (A): **10**
- Discoverability (D): **5**

3. Server Misconfiguration Leading to Information Disclosure (Score: 5)

- Damage (D): **0**
- Reproducibility (R): **10**
- Exploitability (E): **10**
- Affected Users (A): **0**
- Discoverability (D): **5**

Answer the questions below

- What DREAD component assesses the potential harm from successfully exploiting a vulnerability? Damage
- What DREAD component evaluates how others can easily find and identify the vulnerability? Discoverability
- Which DREAD component considers the number of impacted users when a vulnerability is exploited? Affected Users

Task 6 - STRIDE Framework

The STRIDE framework is a threat modelling methodology also developed by Microsoft, which helps identify and categorise potential security threats in software development and system design.

Category	Definition	Policy Violated
Spoofing	Unauthorised access or impersonation of a user or system.	Authentication
Tampering	Unauthorised modification or manipulation of data or code.	Integrity

Repudiation	Ability to deny having acted, typically due to insufficient auditing or logging.	Non-repudiation
Information Disclosure	Unauthorised access to sensitive information, such as personal or financial data.	Confidentiality
Denial of Service	Disruption of the system's availability, preventing legitimate users from accessing it.	Availability
Elevation of Privilege	Unauthorised elevation of access privileges, allowing threat actors to perform unintended actions.	Authorisation

To understand the framework better, let's deep-dive into each category and discuss some examples.

- Spoofing
 - Sending an email as another user.
 - Creating a phishing website mimicking a legitimate one to harvest user credentials.
- Tampering
 - Updating the password of another user.
 - Installing system-wide backdoors using an elevated access.
- Repudiation
 - Denying unauthorised money-transfer transactions, wherein the system lacks auditing.
 - Denying sending an offensive message to another person, wherein the person lacks proof of receiving one.
- Information Disclosure
 - Unauthenticated access to a misconfigured database that contains sensitive customer information.
 - Accessing public cloud storage that handles sensitive documents.
- Denial of Service
 - Flooding a web server with many requests, overwhelming its resources, and making it unavailable to legitimate users.
 - Deploying a ransomware that encrypts all system data that prevents other systems from accessing the resources the compromised server needs.
- Elevation of Privilege
 - Creating a regular user but being able to access the administrator console.
 - Gaining local administrator privileges on a machine by abusing unpatched systems.

In addition, some scenarios may cover multiple STRIDE components.

Scenario	Spoofing	Tampering	Repudiation	Information Disclosure	Denial of Service	Elevation of Privilege
Sending a spoofed email, wherein the mail gateway lacks email security and logging configuration.	✓		✓			
Flooding a web server with many					✓	

requests that lack load-balancing capabilities.						
Abusing an SQL injection vulnerability.		✓		✓		
Accessing public cloud storage (such as AWS S3 bucket or Azure blob) that handles customer data.				✓	✓	
Exploiting a local privilege escalation vulnerability due to the lack of system updates and modifying system configuration for a persistent backdoor.		✓				✓

Threat Modelling With STRIDE

1. **System Decomposition:** Break down systems into components such as applications, networks, and data flows.
2. **Apply STRIDE Categories:** Analyze each component for threats using the six STRIDE categories.
3. **Threat Assessment:** Evaluate the likelihood, impact, and overall risk of identified threats.
4. **Develop Countermeasures:** Implement security controls to mitigate threats and reduce risk.
5. **Validation and Verification:** Test and verify that security controls effectively address identified threats.
6. **Continuous Improvement:** Regularly update the threat model and security measures to address evolving threats.

Application of STRIDE Framework

Scenario: Your e-commerce company is in the process of designing a new payment processing system. To ensure its security and minimise the risk of compromise, you are tasked to conduct a threat modelling exercise using the STRIDE framework. All your assets are stored in a secure cloud infrastructure developed by your system architects.

Team	Roles and Responsibilities
Development Team	Responsible for building systems and applications used by the organisation.
System Architecture Team	Responsible for designing the overall architecture of the cloud services used by the organisation.
Security Team	Provide expertise on threats, vulnerabilities, and risk mitigation strategies.
Business Stakeholder Team	Provides valuable input on critical assets and business processes, and ensures alignment between the initiative and the organisation's

	strategic goals.
Network Infrastructure Team	Manages the organisation's network infrastructure, including servers and critical systems.

Answer the questions below

What foundational information security concept does the STRIDE framework build upon?

CIA Triad

What policy does Information Disclosure violate?

Confidentiality

Which STRIDE component involves unauthorised modification or manipulation of data?

Tampering

Which STRIDE component refers to the disruption of the system's availability?

Denial of Service

Provide the flag for the simulated threat modelling exercise.

THM{m0d3ll1ng_w1th_STR1D3}

Task 7 - PASTA Framework

PASTA (Process for Attack Simulation and Threat Analysis) is a risk-focused threat modeling framework that uses a seven-step methodology to identify threats, assess risks, simulate attacks, and prioritize security improvements.

1. **Define the Objectives:** Identify the systems, scope, security goals, and compliance requirements of the threat modeling exercise.
2. **Define the Technical Scope:** Inventory assets and understand system architecture, dependencies, and data flows.
3. **Decompose the Application:** Break down the system to identify components, entry points, trust boundaries, and attack surfaces.
4. **Analyse the Threats:** Identify potential threats from external attackers, insiders, and other threat sources.
5. **Vulnerabilities and Weaknesses Analysis:** Assess vulnerabilities and weaknesses that could be exploited by attackers.
6. **Analyse the Attacks:** Simulate attack scenarios to evaluate their likelihood, impact, and associated risks.
7. **Risk and Impact Analysis:** Implement security controls and countermeasures to reduce identified risks and strengthen security.

PASTA Methodology Guidelines

Define the Objectives	• Set clear and realistic security objectives for the threat modelling exercise. • Identify relevant compliance requirements and industry-specific security standards.
Define the Technical Scope	• Identify all critical assets, such as systems and applications, that handle sensitive data owned by the organisation.

	• Develop a thorough understanding of the system architecture, including data flows and dependencies.
Decompose the Application	• Break down the system into manageable components or modules. • Identify and document each component's possible entry points, trust boundaries, attack surfaces, data flows, and user flows.
Analyse the Threats	• Research and list potential threats from various sources, such as external attackers, insider threats, and accidental exposures. • Leverage threat intelligence feeds and industry best practices to stay updated on emerging threats.
Vulnerabilities and Weaknesses Analysis	• Use a combination of tools and techniques, such as static and dynamic code analysis, vulnerability scanning, and penetration testing, to identify potential weaknesses in the system. • Keep track of known vulnerabilities and ensure they are addressed promptly.
Analyse the Attacks	• Develop realistic attack scenarios and simulate them to evaluate their potential consequences. • Create a blueprint of scenarios via Attack Trees and ensure that all use cases are covered and aligned with the objective of the exercise.
Risk and Impact Analysis	• Assess the likelihood and impact of each identified threat and prioritise risks based on their overall severity. • Determine the most effective and cost-efficient countermeasures for the identified risks, considering the organisation's risk tolerance and security objectives.

Benefits of Using the PASTA Framework

- **Flexible and adaptable:** Helps organizations align threat modeling activities with business objectives and compliance requirements.
- **Improves collaboration:** Brings together developers, architects, and security teams to create a shared understanding of risks.
- **Supports compliance:** Systematically identifies risks and ensures appropriate security controls are implemented.
- **Provides comprehensive risk analysis:** Uses a structured seven-step approach to identify, evaluate, and mitigate threats proactively.

Application of PASTA Framework

A financial organization uses the **PASTA framework** to evaluate security risks in its online banking platform. By collaborating with different teams, the organization identifies potential threats, analyzes vulnerabilities, and implements security measures to protect customer data and improve cyber resilience.

Team	Roles and Responsibilities
Development Team	Responsible for building systems and applications used by the organisation.
System Architecture Team	Responsible for designing the overall architecture of the cloud services used by the organisation.
Security Team	Provide expertise on threats, vulnerabilities, and risk mitigation strategies.

Business Stakeholder Team	Provides valuable input on critical assets and business processes, and ensures alignment between the initiative and the organisation's strategic goals.
----------------------------------	---

Answer the questions below

In which step of the framework do you break down the system into its components?

Decompose the Application

During which step of the PASTA framework do you simulate potential attack scenarios?

Analyse the Attacks

In which step of the PASTA framework do you create an inventory of assets?

Define the Technical Scope

Provide the flag for the simulated threat modelling exercise.

THM{c00k1ng_thr34ts_w_P4ST4}

Task 8 - Conclusion

Framework	Use Case Applications
MITRE ATT&CK	Unlike DREAD and STRIDE, which focus more on potential risks and vulnerabilities, ATT&CK provides a practical and hands-on approach by mapping adversary tactics. Assess the effectiveness of existing controls against known attack techniques used by threat actors.
DREAD	DREAD offers a more numerical and calculated approach to threat analysis than STRIDE or MITRE ATT&CK, making it excellent for clearly prioritising threats. - Qualitatively assess the potential risks associated with specific threats. - Prioritise risk mitigation based on the collective score produced by each DREAD component.
STRIDE	While other frameworks like MITRE ATT&CK focus on real-world adversary tactics, STRIDE shines in its structure and methodology, allowing for a systematic review of threats specific to software systems. - Analyse and categorise threats in software systems. - Identify potential vulnerabilities in system components based on the six STRIDE threat categories. - Implement appropriate security controls to mitigate specific threat types.
PASTA	Excellent for aligning threat modelling with business objectives. Unlike other frameworks, PASTA integrates business context, making it a more holistic and adaptable choice for organisations. - Conduct risk-centric threat modelling exercises aligned with business objectives. - Prioritise threats based on their potential impact and risk level to the organisation.

- | |
|--|
| <ul style="list-style-type: none">• Build a flexible methodology that can be adapted to different organisational contexts. |
|--|

In general, all these frameworks significantly aid in reducing risks in organisations by:

- Enhancing threat awareness and identifying vulnerabilities
- Prioritising risk mitigation efforts and optimising security controls
- Continuous improvement and adaptation to evolving threats

Threat modeling frameworks provide structured approaches to identify, assess, and mitigate security risks, helping organizations reduce their attack surface and improve cyber resilience.